

CYBER SECURITY OPERATIONS

Complete Glossary of Terms

Phases 02 – 07 · All Definitions, Concepts & Terminology

Aggregation & Normalisation · SOC & SIEM · Service Management · Workflow Automation · Incident Response · Remediation & Recovery

Phase 02 — Normalisation (Data Standardisation)

Term	Definition
Normalisation	The process of transforming raw, source-specific log data into a single consistent schema. Converts timestamps, severity levels, and field names into a universal format before any analysis begins.
ISO 8601	The international standard for representing dates and times (e.g., 2024-02-02T10:15:23Z). All normalised timestamps must be in this format, always in UTC.
Severity Scale	The unified five-level classification used after normalisation: info → low → medium → high → critical. All source-specific scales are mapped to this standard.
Event Type	A normalised label for the type of security event, always written in lowercase_with_underscores format (e.g., authentication_failure, vpn_connection).
Source Type	A required normalised field identifying the origin of an event (e.g., windows_security, firewall, ids, vpn).
additional_details	A JSON object field in the normalised schema used to store all source-specific fields that fall outside the standard template. Original values are preserved here.
Field Mapping	The documented strategy that defines how each field in a source log maps to the corresponding field in the normalised schema, including transformation rules.
Unix Epoch	A timestamp format representing seconds since 1 January 1970 00:00:00 UTC. Must be converted to ISO 8601 during normalisation (e.g., new Date(ts*1000).toISOString()).
Required Fields	The four fields that must always be present in every normalised event: normalised_timestamp, event_type, source_type, and severity. Events missing these are rejected.
Parsing	The step before normalisation. Reads raw log data and extracts individual named fields (timestamp, IP, event type, etc.) based on the log format and structure.
Data Type Conversion	The process of converting source values into consistent types during normalisation — numbers to strings, booleans to YES/NO, arrays to comma-separated strings.
Validation	The final step of normalisation — verifying that all required fields are present, data types are consistent, timestamp formats are correct, and severity mappings are accurate.

Phase 02 — Aggregation (Data Combination & Correlation)

Term	Definition
Aggregation	The process of combining normalised events from multiple sources into a single unified dataset, then grouping and correlating them to produce actionable security intelligence.
Chronological Timeline	A merged, sorted list of all normalised events from all sources ordered by normalised_timestamp. The foundation of aggregation — enables cross-source pattern analysis.
Correlation (Aggregation)	The identification of cause-and-effect relationships between events across different security sources (e.g., VPN failure + Windows auth failure + IDS alert from same IP).
Summary Statistics	Calculated aggregates including event frequencies, failure rates, activity patterns, and counts by type/source/severity. Used to establish baselines and identify anomalies.
Incident Timeline	A phase-by-phase reconstruction of a specific security incident built from correlated events across all sources. Phases typically include initial_access_attempt through attack_blocked.
Attack Pattern	A reusable signature extracted from correlated events. Each pattern has a name, stage sequence, and indicators (source IP, username, timeframe) to improve future detection.
CORR-ID	A unique identifier assigned to a correlation result linking a trigger event to one or more related events across sources (e.g., CORR-001).
INC-ID	A unique identifier for a confirmed incident, including its phase timeline, severity, and status (e.g., INC-001).
PTN-ID	A unique identifier for a documented attack pattern, recording stage sequences and indicators for future threat hunting (e.g., PTN-001).
Enrichment	Adding contextual data from external sources to a security event — such as geolocation for an IP address, threat intelligence tags, or user department information from an HR system.
Baseline	The documented normal level of activity for a system or metric. Deviations from the baseline (e.g., an unusual spike in failed logins) indicate potential security events.

Phase 03 — SOC & SIEM Functions (Real-time Monitoring & Threat Detection)

Term	Definition
SIEM	Security Information and Event Management — the central security monitoring platform that combines SIM (long-term log storage) and SEM (real-time event monitoring) to collect, normalise, correlate and alert on security events.

SIM	Security Information Management — the library component of a SIEM that handles long-term log storage, data retention, compliance reporting, and historical forensic analysis.
SEM	Security Event Management — the live analyst component of a SIEM that monitors events in real time, applies correlation rules, and generates alerts as events arrive.
Correlation Rule	A logical condition programmed into the SIEM that connects multiple events using time windows, correlation keys, and thresholds to detect threat patterns. Goes beyond counting — finds relationships between events.
Correlation Key	The field used to group related events together (e.g., source_ip). Determines which events belong to the same pattern. In a brute force rule, source_ip is the correlation key.
Time Window	The time period within which events must occur to trigger a correlation rule (e.g., 120 seconds). Six failed logins in 6 hours = normal; six in 90 seconds = attack. This is what makes correlation powerful.
Threshold	The minimum count of events required to trigger a correlation rule (e.g., 5 failed logins). Below the threshold = no alert. At or above = alert fires. Setting the right threshold balances sensitivity vs false positives.
Sliding Window	A correlation technique where for each new event, the system looks back (or forward) a fixed time period to check if enough related events have occurred. Moves forward with each event rather than being fixed.
Alert Fidelity	The accuracy of SIEM-generated alerts — the ratio of true positives to total alerts. High fidelity = mostly real threats. Low fidelity = too many false positives. 50% fidelity means half of all alerts are false alarms.
True Positive	An alert that correctly identifies a genuine security incident requiring response (e.g., 192.168.1.100 triggering a brute force alert when it genuinely is attacking).
False Positive	An alert that fires on legitimate, benign activity rather than a real threat (e.g., a monitoring server triggering a brute force rule). Causes alert fatigue and wastes analyst time.
Alert Fatigue	The condition where analysts start ignoring or deprioritising alerts because too many are false positives. A major real-world problem — real attacks get missed in the noise.
Whitelist	A list of known-good sources excluded from triggering alerts (e.g., monitoring servers, backup systems). Essential for reducing false positives and preventing alert fatigue.
IOC	Indicator of Compromise — forensic evidence suggesting malicious activity has occurred or is occurring. Examples: known malicious IP addresses, file hashes of malware, suspicious domain names, anomalous login patterns.
Threat Intelligence	External and internal knowledge about known threats, attack techniques, and adversary behaviour. Fed into the SIEM to give context to raw events and identify IOCs.

Real-time Monitoring	Continuous analysis of security events as they arrive — not batch processing. Enables immediate detection and response. The operational mode of the SEM component.
Contextualisation	Using threat intelligence to add meaning to a raw event — e.g., knowing an IP is on a known-bad list changes how the alert is prioritised.
Behavioural Analytics	Advanced analysis that establishes normal activity patterns and flags deviations as potential threats. Includes UBA (User Behaviour Analytics), EBA (Entity Behaviour Analytics), and NBA (Network Behaviour Analytics).
Aggregation Layer	The SIEM component responsible for collecting and consolidating security data from multiple sources across infrastructure. Handles initial data processing and preparation for analysis.
Baseline Configuration	A documented standard of normal system behaviour used as a reference point for detecting anomalies. Baselines help identify deviations that may indicate security incidents.
Data Enrichment (SIEM)	Enhancing raw security data with additional context from external sources — threat intelligence feeds, asset databases, user directories, and geographical information. Makes events more actionable.
Alert Lifecycle	The complete process through which a security alert moves: Detection → Triage → Investigation → Response → Documentation & Closure.
Risk-based Alerting	An alert generation approach that considers the risk level of affected assets and the potential impact of detected threats when determining alert priority and response.
Audit Trail	A chronological record of system activities providing documentary evidence of security events and user actions. Essential for compliance requirements and incident investigation.
NIST PROTECT	The NIST Cybersecurity Framework function covering safeguards put in place to limit the impact of a security threat. Phases 03 and 05 map to this function.
NIST DETECT	The NIST Cybersecurity Framework function covering activities for identifying when a cybersecurity event has occurred. Phases 03 and 05 map to this function.

Phase 04 — Service Management Integration (NIST GOVERN)

Term	Definition
Service Management Integration	The bridge between security monitoring and operational response. Ensures the efficient delivery, monitoring, and continuous improvement of security services by aligning operational processes with incident response workflows.
SLA	Service Level Agreement — a documented commitment defining expected response times and service quality metrics based on incident

OLA	severity. The SLA deadline is set at ticket creation, not when an analyst picks it up. Operational Level Agreement — an internal agreement defining how different IT groups support external SLAs. Governs internal team responsibilities.
MTTD	Mean Time to Detect — the average time between the onset of an incident and its detection by the security team. Shorter MTTD gives attackers less time in the environment.
MTTR	Mean Time to Resolve — the average time from incident detection to full resolution and closure. A key SLA metric for service management.
KPI	Key Performance Indicator — a metric used to evaluate the success of security service delivery and organisational objectives (e.g., SLA compliance rate, escalation rate).
CMDB	Configuration Management Database — a repository of all hardware, software, and IT infrastructure component information and the relationships between them.
Change Management	The controlled process of planning, testing, implementing, documenting, and reviewing changes to services or infrastructure. Includes emergency, standard, and normal change types.
Service Catalog	A structured document listing all IT services available to the organisation, including descriptions, SLAs, costs, and request procedures.
Incident	Any unplanned interruption or reduction in quality of an IT service.
Major Incident	A high-impact, high-urgency incident requiring escalated response and increased coordination across teams.
Problem	The underlying root cause of one or more incidents.
Known Error	A problem that has been analysed and documented but not yet fully resolved.
Alert Correlation (Phase 04)	Connecting multiple related alerts or incidents to identify patterns and underlying root causes within the service management context.
Escalation Path	The defined route through which incidents are passed to progressively higher levels of support or management based on severity or time elapsed.
BIA	Business Impact Analysis — an assessment of the potential effects of service disruptions on business operations. Used to prioritise recovery order.
Severity Calculation	The 4-step algorithm used to determine final incident severity: (1) start with baseline severity, (2) check event count, (3) check timing (off-hours escalation), (4) check whitelist.
SLA Compliance Rate	The percentage of incidents handled within defined service levels. A key performance indicator for the SOC and service management team.
Escalation Rate	The percentage of tickets requiring management notification. A sudden increase may indicate increased threat activity rather than improved detection.

NIST GOVERN

The NIST Cybersecurity Framework function that Phase 04 maps to. Establishes the governance layer: policies, processes, and oversight ensuring consistent security service delivery.

Phase 05 — Workflow Automation (NIST PROTECT · DETECT · RESPOND)

Term	Definition
Workflow Automation	The systematic automation of repetitive tasks, incident response, and threat management processes to enable faster decision-making and reduce human error.
SOAR	Security Orchestration, Automation and Response — platforms combining orchestration, automation, and incident response capabilities to improve security operations efficiency. Examples: TheHive, Splunk Phantom, Cortex XSOAR.
Playbook	A predefined set of automated procedures designed to handle a specific security scenario or incident type. Contains step-by-step instructions for automated response execution.
Runbook	Detailed technical documentation describing the steps for completing a specific task or process, often including both automated procedures and manual interventions.
Orchestration	The coordination and management of multiple automated tasks, systems, or services to execute complex workflows with proper sequencing and dependency handling.
Trigger	An event or condition that initiates an automated workflow. Can be time-based, event-based, alert-based, or manually activated.
Webhook	An automated message sent from one application to another when a specific event occurs. Enables real-time workflow triggers and integrations between tools.
Connector	A pre-built integration component enabling communication between different systems or applications in an automated workflow.
Condition	A logical test that determines the flow of automation based on specific criteria. Enables dynamic workflow routing and decision-making.
Action (Automation)	A specific task or operation performed as part of a workflow — such as data processing, system configuration, or sending a communication.
API	Application Programming Interface — a set of protocols and tools allowing different software applications to communicate and share data. Fundamental to workflow automation integration.
Task Queue	A system component that manages and orders tasks for processing, ensuring proper sequence and resource allocation in automated workflows.

Data Mapping	Matching fields and data structures between different systems to ensure proper data transfer in automated workflows.
Middleware	Software acting as a bridge between different applications, systems, and databases in an automated workflow.
Exception Handling	Procedures for managing and responding to errors or unexpected conditions in automated workflows.
Fallback Procedure	Alternative actions implemented when primary automation fails or encounters errors, ensuring continuity of the response process.
Low-Code/No-Code	Development approaches enabling workflow automation creation with minimal programming requirements. Examples: Zapier, Microsoft Power Automate.
Automation Rate	A success metric measuring the percentage of tasks handled automatically versus manually. Used to evaluate the effectiveness of automation investment.

Phase 06 — Incident Response (NIST RESPOND · PICERL)

Term	Definition
Incident Response (IR)	The organised approach to addressing and managing the aftermath of a security breach or cyberattack. Limits damage, reduces recovery time and costs, and restores normal operations.
PICERL	The six-phase incident response lifecycle: Preparation → Identification → Containment → Eradication → Recovery → Lessons Learned.
Preparation	The IR phase that happens before any incident. Includes writing playbooks, training staff, configuring tools, and establishing communication plans and escalation paths.
Identification	The IR phase where an alert is triaged to confirm whether it is a genuine security incident, determine its scope and severity, and classify the incident type.
Containment	The IR phase where the team prevents the incident from spreading further. Divided into short-term (immediate isolation) and long-term (hardening) containment.
Short-Term Containment	Immediate actions taken within minutes of incident confirmation to stop the bleeding — isolate system from network, block IP at firewall, disable user account.
Long-Term Containment	Actions taken after the immediate threat is stopped to make the environment safe for continued operation — apply patches, rebuild systems, reset all credentials, segment network.
Eradication	The IR phase where the threat is completely removed from the environment — deleting malware, removing backdoors, patching the root cause vulnerability, and eliminating all persistence.

Recovery (Phase 06)	The IR phase where affected systems are restored to normal operation. Includes restoring from backups, rebuilding systems, and monitoring closely for signs of reinfection.
Lessons Learned	The final IR phase — a structured review of the entire incident. Identifies what went well, what could be improved, updates playbooks, adds new IOCs to threat intelligence.
NIST RESPOND	The NIST Cybersecurity Framework function that Phase 06 maps to. Covers response planning, communications, analysis, mitigation, and improvements after a confirmed incident.
Digital Forensics	The process of collecting, preserving, and analysing digital evidence from computers, networks, and storage devices in a way that maintains integrity for investigation and legal proceedings.
Order of Volatility	The principle that forensic evidence should be collected from most volatile (disappears fastest) to least volatile. Order: CPU/RAM → Processes → Network connections → Disk → Logs.
Chain of Custody	A documented record of who collected evidence, when, how, and everyone who has handled it since. Essential for maintaining evidence integrity and admissibility in legal proceedings.
Forensic Image	A bit-for-bit copy of a storage device that captures everything including deleted files and unallocated space. Created without modifying the original.
Hash / Checksum	A unique digital fingerprint of a file generated by algorithms like MD5 or SHA-256. Used to verify that evidence has not been tampered with since collection.
TTP	Tactics, Techniques, and Procedures — the behaviour patterns and methods used by threat actors. Understanding TTPs helps predict attacker actions and improve detection rules.
Lateral Movement	When an attacker moves from one compromised system to other systems within the network to expand their access and reach their target.
Persistence	Techniques used by attackers to maintain access to a compromised system even after reboots or credential changes. Examples: scheduled tasks, startup scripts, backdoors.
Exfiltration	The unauthorised transfer of data from a system or network to an external location controlled by the attacker.
C2 / Command and Control	Infrastructure used by attackers to communicate with and control compromised systems. Identifying C2 traffic is a key investigation priority during incident response.
Triage	The process of quickly assessing multiple alerts or incidents to prioritise which require immediate attention — determining true positive vs false positive.
Scope Assessment	Determining the full extent of a security incident — which systems were affected, what data was accessed, and how far the attacker penetrated.
Incident Commander	The person who leads and coordinates the incident response. Makes key decisions, manages communications, and oversees the entire response process.

MTTC	Mean Time to Contain — the average time from detection to successful containment of the incident. Shorter MTTC means less damage and spread.
MTTI	Mean Time to Investigate — the average time spent investigating each incident. Tracks analyst efficiency and workload within the IR process.
GDPR Breach Notification	The legal requirement under GDPR for organisations to notify the relevant supervisory authority within 72 hours of becoming aware of a personal data breach.
Tabletop Exercise	A discussion-based simulation where the IR team talks through their response to a hypothetical incident scenario. Tests readiness without involving real systems.
Volatility	Open-source memory forensics framework used to analyse RAM dumps. Can extract running processes, network connections, injected code, and encryption keys from memory.
TheHive	Open-source security incident response platform used for case management, task tracking, evidence collection, and MISP integration during incident response.
MISP	Malware Information Sharing Platform — an open-source threat intelligence platform for storing and sharing IOCs between organisations and IR teams.
Wireshark	Network protocol analyser used to capture and examine network traffic. Used in IR to identify C2 communications, data exfiltration, and lateral movement.

Phase 07 — Remediation, Recovery & Resilience (NIST RECOVER)

Term	Definition
Remediation	The permanent elimination of the vulnerability or weakness that allowed a security incident to occur. Distinct from containment (Phase 06), which is a temporary measure.
Recovery (Phase 07)	The structured process of restoring all affected systems, services, and data to full normal operation after an incident has been resolved.
Resilience	The ability of an organisation to anticipate, withstand, recover from, and adapt to security incidents. Built through long-term improvements implemented after each incident.
Root Cause Analysis (RCA)	A structured method for identifying the fundamental underlying reason an incident occurred, rather than just addressing symptoms. The 5 Whys is a common RCA technique.
The 5 Whys	An RCA technique where you ask 'why?' repeatedly (typically 5 times) until you reach the root cause rather than stopping at a symptom or surface-level explanation.

Post-Incident Review	A structured review of the entire incident conducted after resolution. Produces lessons learned, identifies root causes, and generates improvement recommendations.
RTO	Recovery Time Objective — the maximum acceptable duration of time a system can be offline after a disruption before the business impact becomes unacceptable.
RPO	Recovery Point Objective — the maximum acceptable amount of data loss measured in time. Drives how frequently backups must be taken (e.g., RPO of 4 hours = backup every 4 hours).
NIST RECOVER	The NIST Cybersecurity Framework function that Phase 07 maps to. Covers activities to restore capabilities and services impacted by a cybersecurity incident and maintain resilience plans.
Technical Remediation	Direct technical fixes to systems and software — patching vulnerabilities, updating configurations, replacing compromised components.
Process Remediation	Fixing broken or missing operational processes that contributed to the incident — implementing patch management, creating vendor assessment programmes, updating procedures.
People Remediation	Addressing human factors that contributed to the incident — security awareness training, role reassignment, updated access control policies.
Architectural Remediation	Structural changes to the security architecture — network segmentation, zero-trust implementation, additional authentication layers.
Defence in Depth	A security strategy employing multiple layers of controls so that if one layer fails, others still protect the organisation. Eliminates single points of failure.
Zero Trust	A security model based on 'never trust, always verify.' No user or system is trusted by default, regardless of whether they are inside or outside the network.
Network Segmentation	Dividing a network into isolated segments so that a compromise in one segment cannot easily spread to others. A key resilience measure implemented in Phase 07.
Least Privilege	The principle that users and systems should only have the minimum access required to perform their legitimate functions. Limits attacker movement if credentials are compromised.
Penetration Testing	Authorised simulated attack on a system or network to identify vulnerabilities before real attackers do. A key resilience testing activity.
Red Team Exercise	A full attack simulation where a dedicated team attempts to compromise the organisation using real attacker techniques. Tests the entire security programme.
Bug Bounty Programme	A programme rewarding external security researchers for responsibly disclosing vulnerabilities they find. Extends testing capability cost-effectively.
Security Champions Programme	Designating security-aware individuals within each business or development team to promote security practices and act as a bridge to the dedicated security team.

Third-Party Risk Management	The process of identifying and managing security risks introduced by vendors, suppliers, and partners with access to systems or data.
Patch Management	The systematic process of identifying, acquiring, testing, and installing software patches to address vulnerabilities. A missing patch management process is a common RCA finding.
Vulnerability Management	The ongoing process of identifying, classifying, prioritising, and remediating security vulnerabilities across an organisation's systems.
Integrity Verification	Confirming that files, systems, or backups have not been modified by comparing cryptographic hashes against known-good values.
Forensic Baseline	A known-good snapshot of a system's state used to compare against a potentially compromised system. Created during normal operations as part of incident preparation.
Continuous Improvement	The principle that security is never finished — each incident, test, and review generates findings that improve the overall security programme. Phase 07 feeding back to Phase 01 embodies this principle.
Attack Surface Reduction	Minimising the number of ways an attacker can enter or interact with systems — achieved by disabling unnecessary services, closing ports, and removing unused software.
Security Development Lifecycle (SDL)	A process for building security into software development from the start rather than adding it afterwards. Includes security requirements, design reviews, and code scanning.
MTTR (Recovery)	Mean Time to Recover — the actual average time it takes to restore a system after an incident. Measured against the RTO target. If MTTR > RTO, recovery processes need improvement.

Tools & Platforms Reference (All Phases)

Term	Definition
Security Onion	All-in-one security monitoring platform. Bundles the ELK stack, Zeek, Suricata, and more. Complete VM images available with excellent documentation. Ideal for learning multiple SOC disciplines.
ELK Stack	Elasticsearch, Logstash, Kibana — industry-standard log management and analysis toolchain. Logstash handles normalisation, Elasticsearch provides search, Kibana delivers dashboards.
Graylog	Dedicated log management platform with strong normalisation. User-friendly web interface. Implements correlation through threshold-based detection rules and pipeline processors.
Logstash	Normalisation-focused pipeline tool (part of ELK, also usable standalone). YAML-based configuration with robust parsing and transformation capabilities.

Wazuh	Open-source SIEM/EDR with a dedicated correlation engine. Links related events using defined event rules with parent-child relationships. Also provides file integrity monitoring.
TheHive	Open-source incident response platform for case management, alert triage automation, task tracking, and evidence collection. Integrates with MISP for threat intelligence.
Splunk Phantom	Enterprise SOAR platform with extensive integrations, custom playbook creation, and a rich API ecosystem for security automation.
Cortex XSOAR	Palo Alto's enterprise SOAR platform (formerly Demisto). Multi-source orchestration, automated investigation, and collaborative investigation environment.
Ansible	Security configuration automation tool using a playbook-based, agentless architecture. Used in Phase 07 for automated remediation and patching across multiple platforms.
ServiceNow SecOps	Enterprise ITSM platform with security operations integration — incident management, automated workflows, SLA management, and CMDB integration.
Volatility	Open-source memory forensics framework for analysing RAM dumps. Can extract running processes, network connections, injected malware, and encryption keys.
Autopsy / Sleuth Kit	Disk forensics tools for analysing disk images. Recovers deleted files, examines file system artefacts, and builds file timelines for incident investigation.
FTK Imager	Forensic evidence collection tool that creates bit-for-bit disk images. Preserves evidence without modifying the original and generates cryptographic hashes.
Wireshark	Network protocol analyser for capturing and examining network traffic. Used in IR to identify C2 communications, data exfiltration, and lateral movement.
MISP	Malware Information Sharing Platform — open-source threat intelligence platform for storing and sharing IOCs between organisations and incident response teams.
Velociraptor	Endpoint forensics tool for live response and hunting across multiple endpoints simultaneously. Collects forensic artefacts at scale during investigations.
YARA	Rule-based malware scanning tool that identifies malware by patterns in files. Used during eradication to scan systems for known malware signatures.
Nmap	Network scanning tool used during incident investigation to map network topology, identify unexpected open ports, and discover new or unauthorised systems.
Python	The primary scripting language for security automation. Used across all phases for API integration, data processing, log analysis, and custom tool development.

